

Роли пользователей платформы Russ360

Дата составления: 2026-05-28 · Версия системы: post-M2 cutover, Stage 2 in progress · Аудитория: руководство, владельцы продукта

Содержание

- 1. Зачем этот документ
- 2. Краткая карта 13 ролей и иерархия полномочий
- 3. Матрица возможностей: что какая роль может делать
- 4. Роли подробно — 13 карточек
- 5. Дополнительные уровни доступа (membership, identity)
- 6. Где это контролируется в коде (для техлида)
- 7. Открытые вопросы и каверны

1. Зачем этот документ

Документ отвечает на бизнес-вопросы: *кто такой Региональный руководитель, чем он отличается от Руководителя группы, что доступно полевому Агенту, а что нет*. Без перечисления API-эндпоинтов и кодов разрешений.

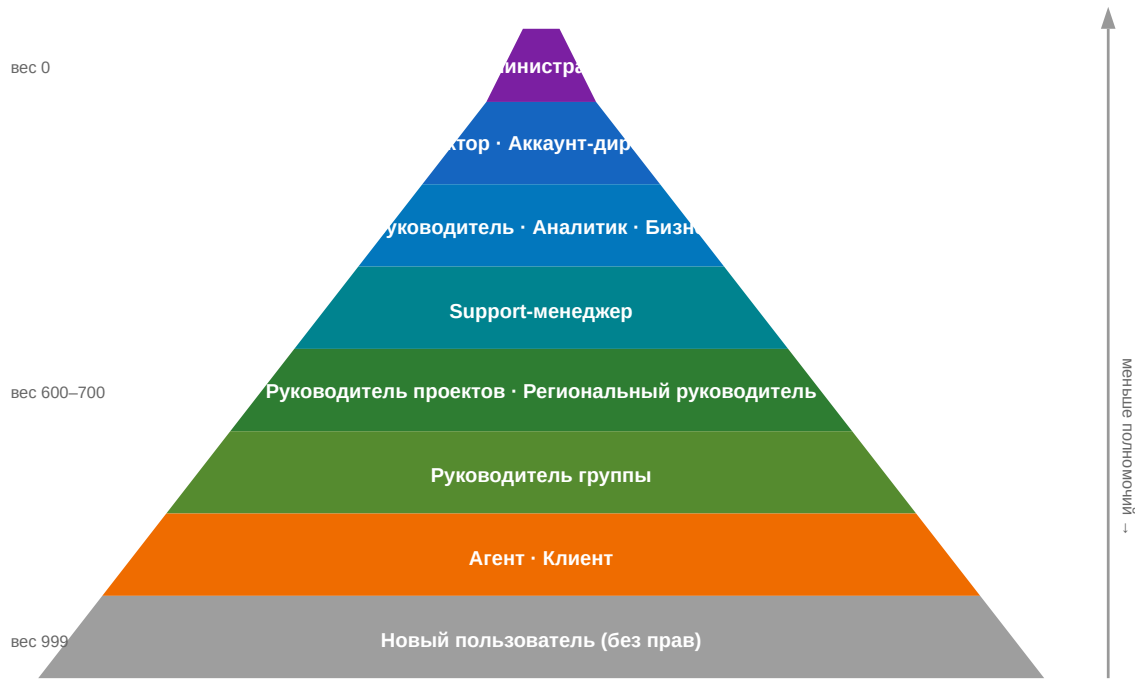
Глобальные роли работают в основной системе **rusaifin** (полевые операции, fintech-UI). Внутри Складского сервиса и SSO есть дополнительные уровни доступа — описаны в разделе 5.

2. Краткая карта ролей

№	Роль	Уровень (меньше = выше)	Кто это в жизни
1	Администратор	0	Системный администратор / разработчик платформы
4	Директор	200	Директор бизнеса — полный доступ к операциям
5	Аккаунт-директор	300	Руководитель аккаунта или направления
6	Support-руководитель	400	Руководитель отдела поддержки
11	Аналитик	401	Сотрудник аналитики и отчётности (только просмотр)
12	Бизнес-тренер	401	Методолог, отвечает за обучение сотрудников
7	Support-менеджер	500	Оператор поддержки, обрабатывает заявки
8	Руководитель проектов	600	Менеджер конкретного проекта
9	Региональный руководитель	700	Руководитель региональной структуры проекта
10	Руководитель группы	800	Старший смены / тимлид над агентами на точках
3	Агент	900	Полевой сотрудник на торговой точке

№	Роль	Уровень (меньше = выше)	Кто это в жизни
13	Клиент	900	Внешний клиент платформы
2	Новый пользователь	999	Только зарегистрировался, ждёт назначения роли

Иерархия ролей — визуальная пирамида



3. Матрица возможностей

Кто что может делать с основными функциональными областями платформы. Это **проектное намерение** — у некоторых функций фактический контроль ослаблен (см. раздел 7).

	Сотрудники	Проекты	Точки	Заявки	Клиенты	Обучение	Документы	Регистрация	Продукты	Свои данные
Администратор	упр	упр	упр	упр	упр	упр	упр	упр	упр	—
Директор	упр	упр	упр	упр	упр	упр	упр	упр	упр	—
Аккаунт-директор	упр	упр	упр	упр	упр	упр	упр	упр	упр	—
Support-руководитель	упр	упр	упр	упр	упр	упр	упр	упр	упр	—
Аналитик	вид	вид	вид	вид	вид	вид	вид	—	вид	—
Бизнес-тренер	вид	—	—	—	—	упр	упр	—	—	—
Support-менеджер	упр	вид	упр	упр	упр	вид	упр	упр	упр	—
Руководитель проектов	упр / в проекте	упр / своё	упр	упр	упр	вид	вид	—	упр	—
Региональный рук-ль	упр / в проекте	упр / своё	упр	упр	упр	вид	вид	—	вид	—
Руководитель группы	упр / в группе	—	свои точки	вид	вид	вид	вид	—	—	—
Агент	—	—	свои	свои	свои	вид	вид	—	—	да
Клиент	—	—	—	—	свои	—	вид	—	—	да
Новый пользователь	—	—	—	—	—	—	—	—	—	—

упр

 Управление (создание / редактирование / удаление)

вид

 Только просмотр

в проекте

 Управление только в своих проектах / группе

свои

 Только свои собственные данные

—

 Нет доступа

4. Роли подробно

1. Администратор

Разработчик или владелец платформы — единственная роль с полным неограниченным доступом.

За что отвечает

- Полный доступ ко всем разделам, всем проектам, всем сотрудникам
- Управление ролями пользователей (повышение, понижение, активация новых)
- Системные настройки
- Доступ к истории операций (audit log)
- Обходит все проверки видимости и фильтры

Что НЕ может

- Ограничений нет

`RoleEnum::ADMIN (role_id=1), hierarchy=0`

2. Директор

Топ-руководитель бизнеса. Полные операционные права, кроме изменения ролей и системных настроек.

За что отвечает

- Видит **всех сотрудников** платформы (без фильтра по проекту)
- Управление всеми проектами и точками
- Управление всеми заявками, клиентами, продуктами
- Управление онбордингом новых сотрудников (заявки на регистрацию)
- Управление обучением и документами
- Управление штрафами и компенсациями (по дизайну, см. каверны)

Что НЕ может

- Не управляет ролями и правами пользователей напрямую (только Администратор)
- Не имеет доступа к чисто техническим системным настройкам

`RoleEnum::DIRECTOR (role_id=4), hierarchy=200`

3. Аккаунт-директор

Руководитель направления или отдельного крупного аккаунта. Близок по объёму прав к Директору.

За что отвечает

- Видит всех сотрудников
- Управление всеми проектами, точками, клиентами
- Управление заявками и регистрацией новых сотрудников
- Управление продуктами, штрафами, компенсациями, программой «приведи друга» (по дизайну)
- Управление документами и обучением

Что НЕ может

- Не управляет инвентарём (складские операции — не его зона)
- Не управляет ролями и системой
- Не имеет полного доступа к истории изменений (только просмотр)

`RoleEnum::ACCOUNT_DIRECTOR (role_id=5), hierarchy=300`

4. Support-руководитель

Руководитель отдела клиентской / полевой поддержки.

За что отвечает

- Видит всех сотрудников
- Управление сотрудниками, заявками, проектами, точками
- Управление клиентами и продуктами
- Управление инвентарём (по дизайну)
- Управление обучением и документами
- Управление онбордингом, чатами и задачами команды

Что НЕ может

- Не управляет штрафами и компенсациями
- Не управляет программой «приведи друга»
- Не имеет доступа к системным настройкам и ролям

`RoleEnum::SUPPORT_SUPERVISOR (role_id=6), hierarchy=400`

5. Аналитик

Read-only роль для построения отчётности и анализа данных по всей платформе.

За что отвечает

- Видит всех сотрудников
- Просмотр всех проектов, точек, заявок, клиентов
- Просмотр всех штрафов, компенсаций, приглашений
- Просмотр обучения и документов (любых)
- Просмотр истории изменений
- Просмотр планов и смен

Что НЕ может

- Ничего **создавать, изменять или удалять** (только `*.get` permissions)
- Не отправляет уведомления, не создаёт задачи

`RoleEnum::ANALYST (role_id=11), hierarchy=401`

6. Бизнес-тренер

Методолог, отвечающий за обучение сотрудников и материалы.

За что отвечает

- Управление учебными материалами (создание, публикация, обновление)
- Управление документами (любыми, для распространения сотрудникам)
- Просмотр списка сотрудников (для назначения обучения)
- Общение с сотрудниками через чаты

Что НЕ может

- Не управляет проектами, сотрудниками, заявками
- Не видит клиентов, продукты, штрафы
- Узкоспециализированная роль — фокус только на обучении

`RoleEnum::BUSINESS_COACH (role_id=12), hierarchy=401`

7. Support-менеджер

Линейный сотрудник поддержки — обрабатывает заявки и общается с клиентами / полевыми.

За что отвечает

- Видит всех сотрудников
- Обработка всех заявок (приём, маршрутизация, закрытие)
- Управление клиентами, продуктами, точками
- Управление онбордингом (регистрация новых)
- Управление инвентарём (по дизайну)
- Управление чатами и задачами

Что НЕ может

- Не управляет проектами (создание / закрытие — не его зона)
- Не управляет обучением (только просмотр)
- Не управляет штрафами и компенсациями
- Нет доступа к истории и системным настройкам

`RoleEnum::SUPPORT_MANAGER (role_id=7), hierarchy=500`

8. Руководитель проектов

Менеджер, отвечающий за один или несколько конкретных проектов.

За что отвечает

- Управление **своими** проектами (где он состоит в Core membership)
- Управление сотрудниками и точками своих проектов
- Управление клиентами, продуктами, инвентарём в своих проектах
- Управление планами и сменами
- Управление чатами и задачами проекта
- Обработка всех заявок

Что НЕ может

- Не видит сотрудников и данные **чужих** проектов
- Не управляет обучением и документами (только просмотр)
- Не управляет онбордингом новых сотрудников платформы
- Не управляет штрафами и компенсациями

`RoleEnum::PROJECT_MANAGER (role_id=8), hierarchy=600`

9. Региональный руководитель

Руководитель региональной части проекта (например, «Юг» внутри федеральной розничной сети).

За что отвечает

- Управление сотрудниками и точками в своих проектах
- Управление клиентами и продуктами в своей зоне
- Управление планами и сменами
- Обработка заявок своих проектов
- Чаты и задачи команды

Что НЕ может

- Не видит сотрудников / проекты вне своих Core memberships
- Не управляет обучением и документами (только просмотр)
- Не управляет онбордингом

«Регион» как явная сущность в системе на 2026-05-28 **отсутствует** — региональность реализована через привязку к точкам / проектам. См. docs/russ360-audit-2026-05-18.md и ADR-0006.

RoleEnum::REGIONAL_DIRECTOR (role_id=9), hierarchy=700

10. Руководитель группы

Старший смены / тимлид над агентами на конкретных торговых точках.

За что отвечает

- Управление своей группой агентов (на точках, где он назначен ролью `leader`)
- Просмотр заявок группы
- Управление планами смен
- Просмотр своих точек и клиентов на них
- Чаты с командой

Что НЕ может

- Не видит сотрудников вне своих точек
- Не управляет проектами и точками (создание / закрытие)
- Не управляет продуктами и инвентарём
- Не управляет обучением (только просмотр)

RoleEnum::GROUP_LEADER (role_id=10), hierarchy=800

11. Агент

Полевой сотрудник на торговой точке — основной массив пользователей платформы.

За что отвечает

- Видит свои назначенные точки (где у него assignment agent в Core)
- Видит свои смены и планы
- Просматривает своих клиентов (которые работают на его точках)
- Просматривает обучение и материалы
- Получает уведомления
- Просматривает свои заявки

Что НЕ может

- Не видит других сотрудников и их данные
- Не управляет ничем (всё в режиме просмотра **своих** данных)
- Не видит финансовые данные других агентов

RoleEnum::AGENT (role_id=3), hierarchy=900

12. Клиент

Внешний клиент платформы — не сотрудник, конечный получатель услуг (например, бизнес-заказчик ВАТ-проектов).

За что отвечает

- Просмотр своей карточки клиента
- Просмотр документов, доступных клиенту
- Получение уведомлений
- Просмотр чатов с поддержкой

Что НЕ может

- Не видит внутреннего функционала (сотрудников, проектов, отчётов)
- Не управляет ничем — полностью изолирован от внутренней операционной среды

RoleEnum::CLIENT (role_id=13), hierarchy=900

13. Новый пользователь

*Пользователь, прошедший базовую регистрацию, но ещё не получивший рабочую роль.
Промежуточный статус.*

За что отвечает

- Может залогиниться и заполнить анкету для активации
- Ждёт назначения нормальной роли от Support / HR

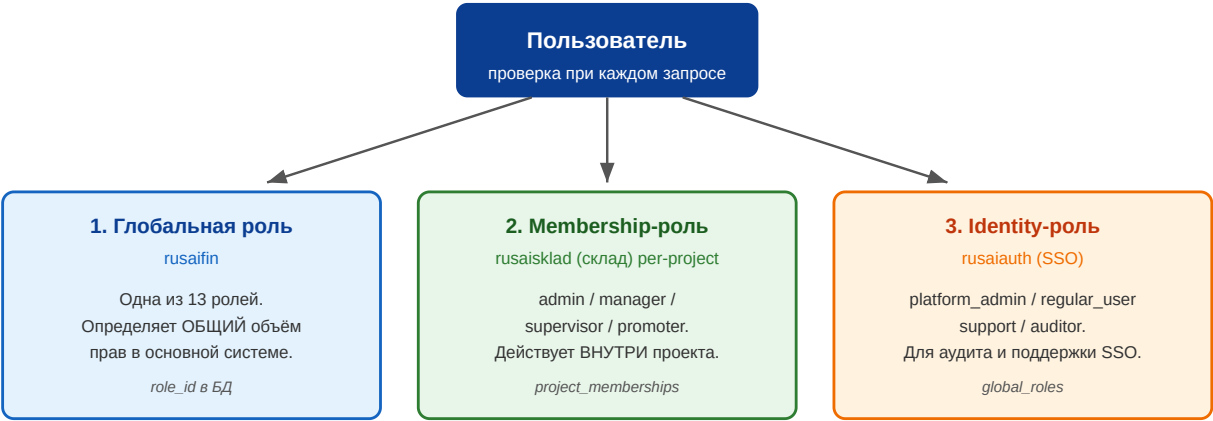
Что НЕ может

- Не имеет вообще никаких прав в системе
- Не видит ни одного раздела платформы
- Не может работать до перехода в роль Агент / Клиент / иное

`RoleEnum::REGISTERED (role_id=2), hierarchy=999`

5. Дополнительные уровни доступа

Глобальная роль `rusaifin` — основная, но не единственная. На каждого пользователя могут накладываться ещё два уровня:



Все три уровня действуют одновременно — фактический доступ = пересечение разрешений всех контуров

Membership-роли в Складском сервисе

Действуют **внутри одного проекта** поверх глобальной роли. Один сотрудник может иметь разные membership-роли в разных проектах (например, `admin` в одном проекте и `promoter` в другом).

Код	Назначение
<code>admin</code>	Полный доступ ко всем складским операциям проекта
<code>manager</code>	Управление операциями (приходы, расходы, инвентаризации)
<code>supervisor</code>	Контроль операций, частичное управление
<code>promoter</code>	Полевая роль на точке — выполнение операций по складу

Identity-роли в системе единого входа

Техническая классификация для аудита и поддержки SSO. На функциональный доступ не влияет — только на операции внутри SSO и логирование.

Код	Назначение / маппинг
<code>platform_admin</code>	Маппится из <code>rusaifin</code> -ролей: Администратор, Директор, Аккаунт-директор
<code>regular_user</code>	Основная масса пользователей: Агент, Руководители, Клиент, Новый пользователь
<code>support</code>	Support-менеджер, Support-руководитель
<code>auditor</code>	Резервная роль, на сегодня практически не используется

6. Где это контролируется (для техлида)

- **Перечень ролей:** `rusaifin/app/Enum/RoleEnum.php` + `database/seeder/MakeDefaultRoles.php`
- **Назначение прав ролям:** `database/seeder/System/AssignDefaultPermissionsSeeder.php`
- **Активные permission-slug'и в БД:** `database/seeder/RolePermissionsSeeder.php`
- **Кто кого видит:** `app/Services/Staff/StaffVisibilityScopeService.php`. Метод `isPrivilegedViewer()` определяет 5 ролей с неограниченным обзором: ADMIN, DIRECTOR, ACCOUNT_DIRECTOR, SUPPORT_SUPERVISOR, ANALYST
- **Привязка к проектам:** прочие роли (PROJECT_MANAGER, REGIONAL_DIRECTOR, GROUP_LEADER, AGENT, SUPPORT_MANAGER) — через Core `project_memberships`
- **Привязка к точкам:** GROUP_LEADER (assignment role= leader), AGENT (assignment role= agent) — через Core `operational_location_assignments`
- **Middleware на роутах:** `CheckPermission::class.':<slug>'` в `routes/api.php` и `routes/web.php`
- **Прямые проверки в контроллерах:** ~112 мест читают `$user->role_id` напрямую (см. аудит `docs/russ360-audit-2026-05-18.md`, P1)

7. Открытые вопросы и каверны

Главная каверна: в коде есть разрыв между декларацией прав ролям и реальным enforcement'ом. Описания возможностей в этом документе соответствуют **проектному намерению**, фактический контроль может быть слабее.

1. **Разрыв «декларация vs реальность» в permissions.** В `AssignDefaultPermissionsSeeder.php` ролям списываются права на сущности, которых нет в таблице `permissions` (`shifts.*`, `plans.*`, `chats.*`, `tasks.*`, `notifications.*`, `inventory.*`, `penalties.*`, `compensations.*`, `bringfriend.*`, `product.*`, `role.*`, `settings.*`, `history.*`). В коде стоит `?? null` → эти permission-id тихо отфильтровываются. По факту в БД активны только: `client.*`, `staff.*`, `application.*`, `registration.*`, `education.*`, `docs.*`, `project.*`, `point.*`, `administration.management`.
2. **Двойной контур авторизации в коде.** Часть проверок — через permission-slug в middleware (`CheckPermission`), часть — через прямые сравнения `role_id == X` в ~112 контроллерах. Это значит, что изменение прав через таблицу `role_permission` не покроеет всех ограничений — часть зашита в код.
3. **rusaicore без enforcement.** Микросервис справочников (`rusaicore`) на сегодня не проверяет роли вообще, полагается на upstream-rusaifin. Любой клиент с валидным OAuth-токеном может вызывать его эндпоинты.
4. **Региональность не моделируется явно.** Роль «Региональный руководитель» работает через привязку к точкам, а не через сущность «Регион». ADR-0006 фиксирует понятие «Территория» (операционная зона между Project и OperationalLocation), но в коде на 2026-05-28 ещё не реализован.
5. **Отсутствующие роли в RoleEnum.** Бизнес-роли «Мерчандайзер» и «Супервайзер» исторически были в старых сидерах `rusaifin`, но в текущем `RoleEnum.php` их нет. На прод-данных их использовать нельзя.

6. **Membership-роли sklad не покрыты глобальной таблицей permissions.** Контроль на стороне `rusaisklad_back` делается через собственный enum, ограничения защиты в бизнес-логику складских контроллеров (нет единого decision-point).

Ответственный за актуализацию: при изменении `RoleEnum.php` , `MakeDefaultRoles.php` или `AssignDefaultPermissionsSeeder.php` синхронизировать карту и описания ролей с кодом.

Источник: `docs/roles-and-capabilities.md` (markdown-исходник). Этот HTML/PDF — производная для печати и рассылки.